

FooDiet

Contenido

- 1. La empresa 2
- 2. Recursos compartidos 2
- 3. Servidores..... 3
- 4. Usuarios y grupos..... 3
- 5. Permisos 4
- 6. Acceso remoto 4
- 7. Seguridad de la red 4
- 8. Otras medidas de seguridad..... 5

1. La empresa

FooDiet es una clínica de nutrición y dietética. Los clientes vienen a consulta con un dietista, que les hace un plan de alimentación personalizado y hace seguimiento de cómo van evolucionando.

Hay unas 7 personas trabajando: recepción (1), nutricionistas (1) más los admins (5).

Para el día a día usan una app web propia con cinco módulos: Administración, Estadísticas, Gestión de pacientes y citas, Gestión de profesionales y Gestión de planes alimenticios.

La información que manejan es sensible: datos médicos, dietas, historial del paciente... así que hay que tener cuidado con quién puede ver qué. La ley de protección de datos (LOPDGDD) también lo exige.

2. Recursos compartidos

App web: el recurso principal. Todos la usan desde el navegador. Cada usuario ve solo lo que le corresponde según su rol.

Base de datos: guarda toda la información (pacientes, citas, planes...). No se accede directamente, solo lo hace la app.

Carpetas compartidas en el servidor interno:

- **Documentación admin:** contratos, facturas. Solo accede administración.
- **Material clínico:** plantillas de dietas, guías. Para los nutricionistas.
- **Informes:** estadísticas y resúmenes. Solo dirección.

Impresoras en red: dos impresoras compartidas. Una en recepción y otra en consultas.

Backup en la nube: copias de seguridad automáticas. Solo lo gestiona el administrador.

3. Servidores

Servidor	Para qué sirve	Lo usa...	Dónde
Web	Aloja la aplicación. Es al que se conectan todos con el navegador.	Todo el personal	Nube
Base de datos	Guarda todos los datos. Solo habla con él la app, no los usuarios.	Solo la app web	Nube
Archivos	Almacena las carpetas compartidas internas.	Personal (según permisos)	Local
Backups	Copias automáticas de la BD y los archivos.	Solo el admin	Nube

El servidor web y la BD están en la nube para no tener que mantener hardware. El de archivos es local porque se usa mucho durante el día y así va más rápido.

4. Usuarios y grupos

Cada trabajador tiene su usuario. Los agrupamos por rol para no tener que configurar permisos uno a uno:

- **Administradores del sistema:** acceso total. Solo 1-2 personas.
- **Dirección:** ven informes y estadísticas, nada clínico.
- **Administración:** gestionan citas y facturación, sin acceso a historiales.
- **Nutricionistas:** trabajan con los datos clínicos de sus pacientes.
- **Pacientes:** solo ven su propio perfil, plan y citas.

5. Permisos

La regla es simple: cada uno accede solo a lo que necesita. Algunos ejemplos:

- Un paciente ve su plan y sus citas. No puede ver nada de otros pacientes.
- Una nutricionista edita los planes de sus pacientes, pero no puede meterse en los de sus compañeras.
- Administración gestiona citas y facturas, pero los datos clínicos no aparecen en su pantalla.
- Dirección consulta estadísticas globales, pero no puede editar nada.

En las carpetas: admin solo lee y escribe en la suya, los nutricionistas en la de material clínico, y los informes solo los abre dirección.

6. Acceso remoto

A veces hay que trabajar desde fuera (un nutricionista en casa, el admin un fin de semana...). Para que sea seguro:

- **HTTPS:** toda la comunicación con la app va cifrada.
- **2FA:** si entras desde fuera de la red, el sistema pide un código extra al móvil.
- **VPN:** para acceder al servidor de archivos desde fuera se usa una VPN.
- **SSH:** el admin gestiona los servidores con SSH, restringido a IPs conocidas.

7. Seguridad de la red

Firewall

Ponemos un firewall entre el router e internet y la red interna. Filtra el tráfico y bloquea cualquier intento de conexión no autorizada desde fuera. Solo deja pasar lo que tiene sentido (por ejemplo, tráfico web al servidor).

El servidor web en la nube tiene su propio firewall configurado desde el panel del hosting.

Más medidas

- **Red de invitados separada:** los pacientes que se conectan al WiFi van a una red diferente. No pueden llegar a los recursos internos.
- **Actualizaciones al día:** sistemas operativos y apps siempre actualizados para no dejar huecos.

8. Otras medidas de seguridad

- **Copias de seguridad diarias:** automáticas por la noche, guardadas en local y en la nube.
- **Antivirus en todos los equipos:** con actualizaciones automáticas.
Importante porque se reciben archivos de pacientes por correo.
- **Datos cifrados:** tanto en tránsito (HTTPS) como en la base de datos.
Obligatorio por la LOPDGDD.
- **Política de contraseñas:** mínimo 8 caracteres, caducan cada 6 meses y se bloquean tras varios intentos fallidos.
- **Bloqueo automático de sesión:** si el equipo lleva 5 minutos sin actividad, se cierra la sesión.
- **Formación al personal:** una pequeña sesión para que sepan identificar correos de phishing y no abran cosas raras.
- **Registro de actividad:** el sistema guarda quién entra, cuándo y qué hace.
Útil para detectar cosas raras.